

ICT2216
Secure Software Development
Trimester 3, AY2025/2026

Team Project

1. **Objective:** Experience the application of secure software development principles in the design and development of real-world secure software.
2. **Project Topic:** Minimum a real-world Secure Web Application with User Login via web browser, e.g., e-Commerce, Internet banking for a fictitious bank, discussion forums, etc. If your team wishes to excel, with the extension option to access via mobile browser or mobile app, to keep up with current trends.
3. **Team Formation:**
 - Size of 7 to a maximum of 8 members with your choice
4. **Deliverables and Grading Scheme:**

Item	Deliverables	Due	Weightage
1	One page project proposal: • Team Members and Lab Group Number • Team Name • Project Title • Project Description • Programming languages and packages to be used • Declaration that your secure web app to be developed is not an adaption of existing codes Evaluation criteria: • Required information above • Creativity and Impact Note: Some of third-party libraries (e.g., OAuth) are NOT allowed to be used in the project. Please discuss with lab instructors on your libraries.	Week 2, Thursday 14 May 9:00 am	5%
2	Report I on Secure Software Requirement Analysis and Design including: Note: Your team is to function as a development team in a company - Secure Software Requirement Analysis: • Functional/Non-Functional requirements • Security requirements • Abuse/misuse cases - Secure Software Design: • Threat modelling • Attack surface analysis • Security architecture • Security design	Week 6, Thursday 11 June 9:00 am	20%

	- Page limit: 30 pages (excluding the appendices-marker does not need to read)		
	Peer Appraisal I (Applied to Project Proposal and Deliverables 1 to derive individual grade)	Online	
3	Report II on Secure Software Implementation, including: Note: Your team is to function as a development team in a company - Secure Implementation: - Describe your implemented CI/CD process and all tools used by your team - List and explain the organization of directory and files of your source codes (which will be cloned for grading) - Explain your code structures using suitable UML diagrams, e.g., class diagram, package diagram, sequence diagram, communication diagram, etc. that you have learned in INF2001 Introduction to Software Engineering - Explain using evidence of your implemented code snippets (state clearly from which file) that your team has adopted the recommended best practices, e.g., from OWASP practices and/or others to securely implement your web app - Test-Driven Development and Test Automation - List all dependencies and provide evidence of implementing dependency check - Evidence of automated testing that your team has coded and run during implementation phase - Elaborate any findings worth of learning and sharing that your team has discovered during your automated testing - Page limit: 30 pages (excluding the appendices: marker does not need to read)	Week 10, Thursday 9 July 9:00 am	25%
	Peer Appraisal II (Applied to Deliverables 2 to derive individual grade)	Online	
4	Report III on Secure Software Verification and Testing, including: Note: Your team is now to function as the QA team within the same company as the one development team to be assigned, NOT attacker - Source Code Review: - Manually perform source code review of the codes of the assigned team (You'll be given Report II and source codes of the assigned team) and report findings - Recommend how to fix the findings, but do NOT fix them	Week 13, Monday 27 July 9:00 am	20%

	Static App Security Testing (SAST): • Perform automated SAST on the codes of the assigned team and report findings • Static Code Analysis can use Generative AI • Recommend how to fix the findings, but do NOT fix them Dynamic App Security Testing (DAST) • Perform DAST on the hosted web app of the assigned team • Recommend how to fix the findings, but do NOT fix them Conclusion: • Rate the security level (1 min and 5 max) and usability level (1 min and 5 max) of the assigned team • Justify your ratings Your Report III will be shared with an assigned Development Team for learning purpose. • Page limit: 35 pages (excluding the appendices: marker does not need to read)		
5	One page of PowerPoint for Rebuttal (Optional)	Week 13, Thursday, 30 July 9:00 am	
	Peer Appraisal III (Applied to Deliverables 3 and Final Presentation to derive individual grade)	Online	